- Defining roles ensures accountability. Each policy has a designated owner, reviewers, and approver.
- Shared processes ensure consistency. All policies and templates undergo the same review, testing, and deployment procedures before they can influence production decisions.
- Operational feedback fosters improvement. ACME's incident management system lets engineers flag any ticket involving access control. These incidents are reviewed by the governance team to identify root causes and decide if new policies, updates, or training are needed.
- Documentation and traceability maintain institutional memory. Architectural Decision Records (ADRs), policy metadata, and incident references are connected, creating a chain from business requirements to operational outcome.

This framework balances central oversight with distributed ownership. Each team can act quickly within established boundaries, while the governance structure offers the continuity and assurance needed to maintain the integrity of ACME's authorization environment.

14.3.2 Roles and responsibilities

A governance framework relies on clearly defined roles. Each role at ACME carries both technical and organizational accountability, ensuring policies align with the company's intent and operate safely across systems. These roles balance distributed ownership with coordinated oversight, enabling teams to act independently within a shared governance structure.

At ACME, the policy *owner* and *approver* are usually the same person: the team manager responsible for the product or feature area. The policy *author* is typically the engineer with architectural responsibility for the affected component, although authorship can be delegated to another team member. Each policy must also have at least one *reviewer*, typically another engineer on the same team, who evaluates it through the standard code review process. To prevent conflicts of interest, ACME's version control system enforces a strict rule: The reviewer cannot also be the author.